PENJELASAN PROYEK

AgentGate

Gateway persetujuan untuk tool call AI agent: aksi aman langsung jalan, aksi berisiko menunggu persetujuan manusia, aksi terlarang ditolak, dan semuanya tercatat.

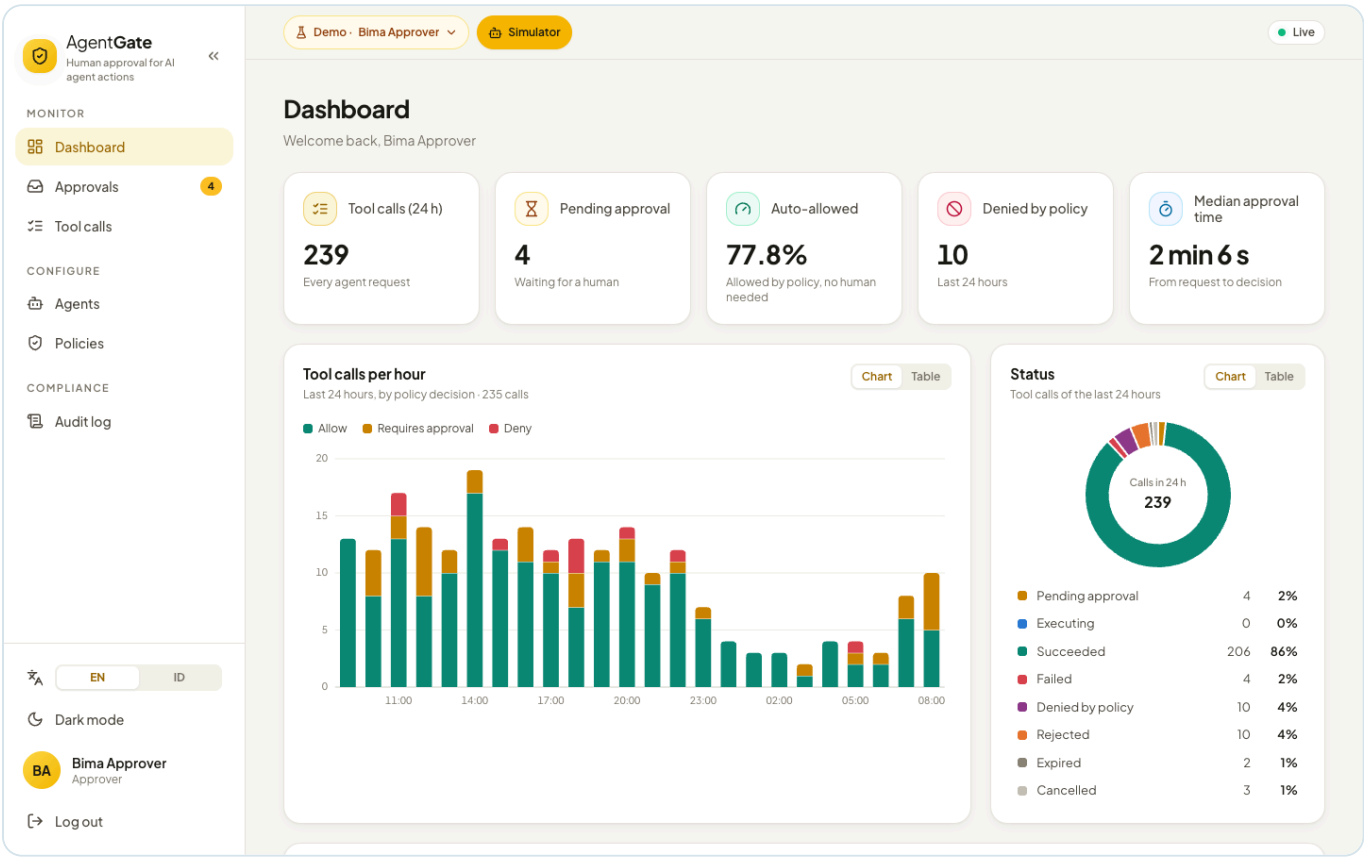
Raihan Evanza · Fullstack & Mobile Developer · portfolio-raihan-evanza.vercel.app

PERAN
Proyek pribadi · desain sistem, backend, web, mobile, deploy

PLATFORM
Web (console) · Android & iOS (aplikasi approver) · API gateway untuk agent

TAUTAN
Demo live: raihan-evanza-agentgate.vercel.app/?as=approver

Go 1.25 · Gin · GORM + pgx · PostgreSQL 17 · Server-Sent Events · React 18 · TypeScript · Vite · Redux Toolkit (RTK Query) · Tailwind CSS · React Native 0.87



RINGKASAN

AI agent seperti bot customer service, asisten data, atau bot ops makin sering diberi akses ke tool yang punya efek nyata: refund, menulis ke database, mengirim email, sampai deploy ke production. Tanpa lapisan kontrol, pilihannya hanya dua: beri akses penuh, atau jangan pakai agent sama sekali.

AgentGate berdiri di antara agent dan tool. Setiap panggilan dievaluasi policy per tool: aksi aman langsung dijalankan (HTTP 200), aksi berisiko menunggu keputusan approver (202), dan aksi terlarang ditolak (403). Approver memutuskan dari console web atau aplikasi mobile, pemilik agent tidak boleh menyetujui aksi agent-nya sendiri, dan setiap langkah masuk log audit.

Hasilnya berupa backend Go + PostgreSQL dengan dua API (gateway untuk agent, console untuk manusia), console web React dengan update realtime, dan aplikasi React Native untuk approver. Demo web berjalan penuh di browser, lengkap dengan simulator agent, sehingga bisa dicoba tanpa server.

FITUR UTAMA

Gateway untuk agent

Agent memanggil POST /gw/v1/calls dengan API key dan mendapat 200 (sudah dijalankan), 202 (menunggu persetujuan), atau 403 (ditolak policy). Untuk 202, agent menunggu hasil lewat long-poll hingga 30 detik per request.

Policy engine per tool

Setiap tool punya level risiko, efek default, batas waktu persetujuan, dan rule berurutan dengan kondisi pada argumen, misalnya amount > 10.000.000 → Tolak atau sql cocok dengan pola drop|truncate → Tolak. Rule pertama yang semua kondisinya terpenuhi yang menentukan.

Inbox persetujuan

Tool call yang menunggu diurutkan dari yang paling dekat kedaluwarsa, lengkap dengan hitung mundur. Approver bisa menyetujui atau menolak; penolakan wajib disertai catatan yang ikut dikirim ke agent.

Pemisahan tugas

Pemilik agent tidak bisa menyetujui atau menolak tool call agent-nya sendiri, termasuk bila ia admin. Tombol Setujui tetap tampil tetapi terkunci, dengan penjelasan bahwa orang lain yang harus memutuskan.

Realtime tanpa refresh

Server-Sent Events mendorong tool call baru dan perubahan status ke console: badge jumlah menunggu, daftar, halaman detail, dan dasbor ikut berubah. Indikator Live di header menunjukkan status koneksi.

Dasbor dan log audit

Dasbor menampilkan tool call 24 jam, persentase yang otomatis diizinkan, yang ditolak policy, median waktu persetujuan, grafik per jam per keputusan, dan donat status, masing-masing bisa diganti ke tabel. Log audit mencatat login, keputusan, dan perubahan agent beserta nilai lama/baru dan alamat IP.

Manajemen agent dan API key

Admin mendaftarkan agent dan menerima API key yang hanya ditampilkan sekali; yang disimpan hanya hash SHA-256–nya. Key bisa dirotasi (key lama langsung tidak berlaku) dan agent bisa ditangguhkan.

Aplikasi mobile untuk approver

Aplikasi React Native (Android + iOS) berisi inbox menunggu dengan badge dan hitung mundur, tombol setujui/tolak, serta feed aktivitas, supaya keputusan bisa diambil dari ponsel.

Simulator agent, dua bahasa, mode gelap

Di demo, panel Simulator memanggil gateway sebagai agent dengan enam skenario (cek pesanan, refund kecil/besar, DROP TABLE, deploy production, refund gagal) dan menampilkan respons HTTP-nya. Antarmuka tersedia dalam Bahasa Indonesia dan Inggris, dengan tema terang/gelap.

ARSITEKTUR & ALUR DATA

AI agent
Memanggil /gw/v1 dengan API key agk_..., opsional Idempotency-Key.

→

Gateway API (Gin)
Validasi argumen terhadap skema tool, lalu evaluasi policy.

→

Policy & usecase
ALLOW → eksekusi, REQUIRE_APPROVAL → simpan dan tunggu, DENY → tolak.

→

PostgreSQL 17
Tool call, hash argumen, timeline, dan audit dalam satu transaksi.

→

Console web / app mobile
Approver menerima event SSE, lalu menyetujui lewat /api dengan JWT.

- Satu binary Go melayani dua API: Gateway API untuk agent (API key) dan Console API untuk manusia (JWT). Aturan bisnis ada di lapisan usecase dan policy; controller hanya mem-parsing request dan mengirim respons.
- Setelah approver menyetujui, status berpindah ke EXECUTING, tool dijalankan dengan argumen yang tersimpan, lalu hasilnya membangunkan long-poll agent dan dikirim ke console lewat SSE.

- Worker latar belakang menandai persetujuan yang lewat batas waktu sebagai kedaluwarsa, dan tool call yang terhenti di EXECUTING karena restart dijadikan FAILED, tidak dijalankan ulang otomatis.
- Di demo Vercel, seluruh backend (policy engine, tool sandbox, kedaluwarsa, event realtime) digantikan adapter di browser yang menyimpan data di localStorage.

TEKNOLOGI PER LAPISAN

Backend	Go 1.25 · Gin · GORM + pgx · Viper · golang-jwt + bcrypt · go-i18n · zap · Swaggo (Swagger) · Testify + GoMock
Database	PostgreSQL 17 (Docker) · Unique (agent, Idempotency-Key) · Guarded status UPDATE
Web	React 18 · TypeScript · Vite · Redux Toolkit (RTK Query) · React Router · react-hook-form + yup · Tailwind CSS · Rupa Design System (@rupa-ui/react, signal) · Vitest · Vercel
Mobile	React Native 0.87 (New Architecture, Hermes) · Rupa Design System (@rupa-ui/react-native, signal) · React Navigation 7 · RTK Query · react-native-keychain

KEPUTUSAN TEKNIS

1. **Gagal-tertutup (fail-closed)**
   Bila tidak ada rule yang cocok, efek default tool yang dipakai. Bila sebuah kondisi tidak bisa dievaluasi (tipe tidak cocok atau pola regex rusak), evaluasi berhenti dengan REQUIRE_APPROVAL. Kesalahan policy tidak pernah berujung ALLOW.

2. **Yang disetujui = yang dijalankan**
   Saat request masuk, hash SHA-256 dari JSON argumen (bentuk kanonik) disimpan. Eksekusi memakai argumen yang tersimpan dan memeriksa ulang hash-nya, jadi argumen tidak bisa diubah setelah approver melihatnya.

3. **Keputusan aman dari balapan**
   Setiap perpindahan status berupa UPDATE … WHERE id = ? AND status = ? dalam satu transaksi bersama timeline dan audit. Jika dua approver menekan bersamaan, hanya satu yang berhasil dan yang lain mendapat 409; menyetujui tool call yang sudah lewat batas waktu juga ditolak.

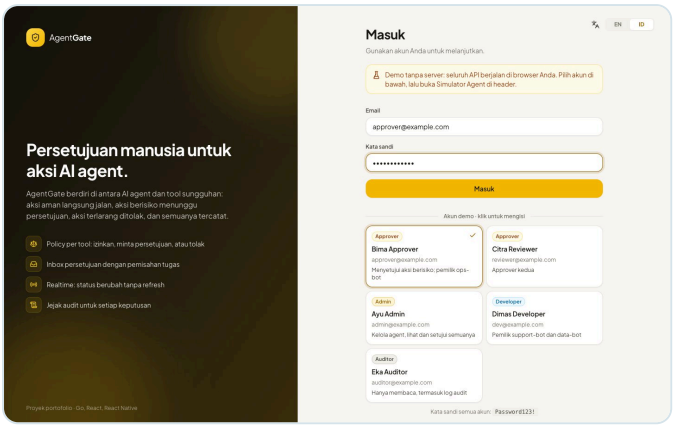
4. **Idempotency dan efek samping paling banyak sekali**
   Pasangan (agent, Idempotency-Key) unik di database, sehingga request ganda yang datang bersamaan hanya membuat satu tool call; ini diuji integrasi terhadap PostgreSQL sungguhan. Tool call yang terputus karena crash tidak dijalankan ulang, supaya refund atau deploy tidak terjadi dua kali.

5. **Satu set test vector untuk dua engine**
   Policy engine ditulis dua kali: di Go untuk backend dan di TypeScript untuk demo browser. Keduanya menjalankan 39 test vector yang sama dari satu file JSON, sehingga demo memutuskan persis seperti server.

6. **Data sensitif dimasking di mana-mana**
   Field yang ditandai sensitif (misalnya customer_email dan isi email) diganti *** di respons console, pratinjau, dan log audit. Hanya executor yang melihat nilai aslinya.

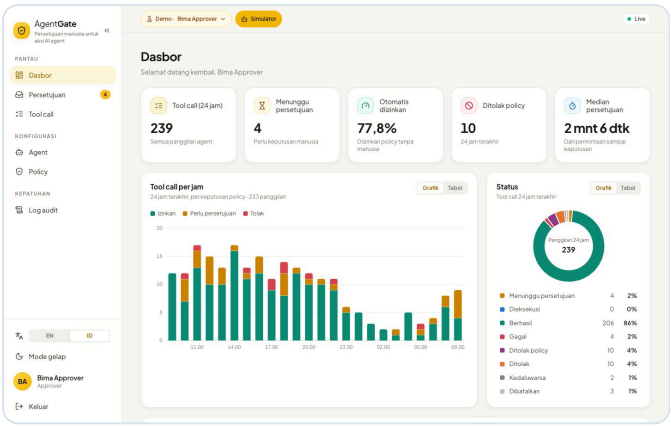
PANDUAN PENGGUNAAN

Langkah-langkah ini sama dengan urutan di video tutorial.



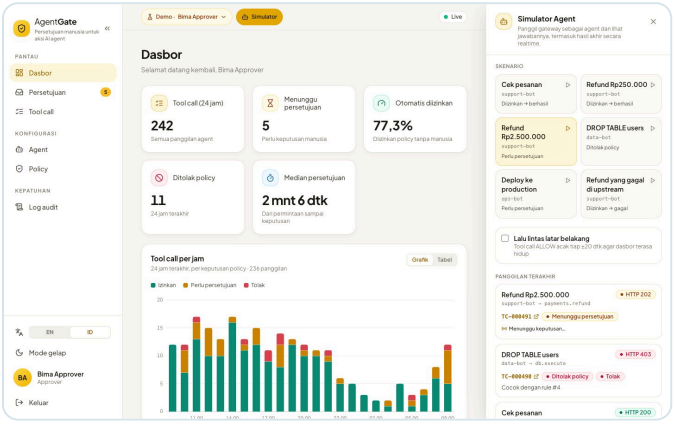
1 Masuk dengan akun demo

Buka demo, klik kartu Bima Approver untuk mengisi email dan password otomatis, lalu klik Masuk. Ada lima akun demo per role (Approver, Approver kedua, Admin, Developer, Auditor) dengan password Password123!. Tautan /?as=approver langsung masuk sebagai Bima.



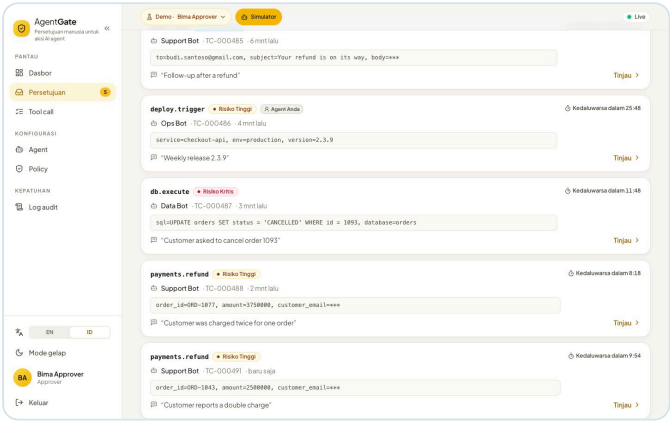
2 Lihat dasbor

Kartu di atas menunjukkan tool call 24 jam, yang menunggu persetujuan, persentase yang otomatis diizinkan, yang ditolak policy, dan median waktu persetujuan. Di bawahnya ada grafik tool call per jam per keputusan policy dan donat status.



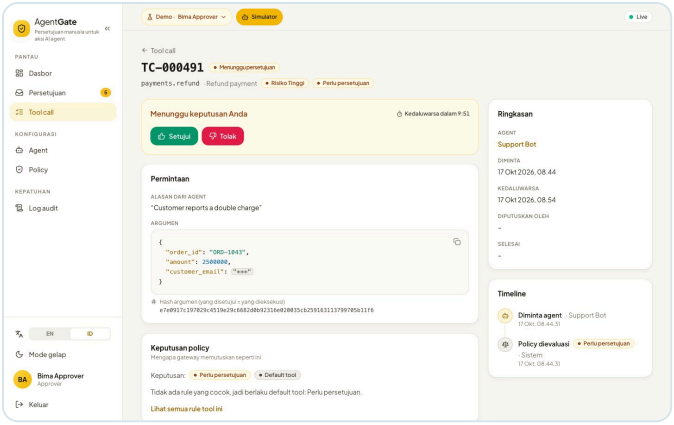
3 Panggil gateway lewat Simulator

Klik Simulator di header, lalu jalankan Cek pesanan (HTTP 200, langsung berhasil), DROP TABLE users (403, ditolak rule #4), dan Refund Rp2.500.000 (202, menunggu persetujuan). Badge Persetujuan di sidebar bertambah tanpa refresh.



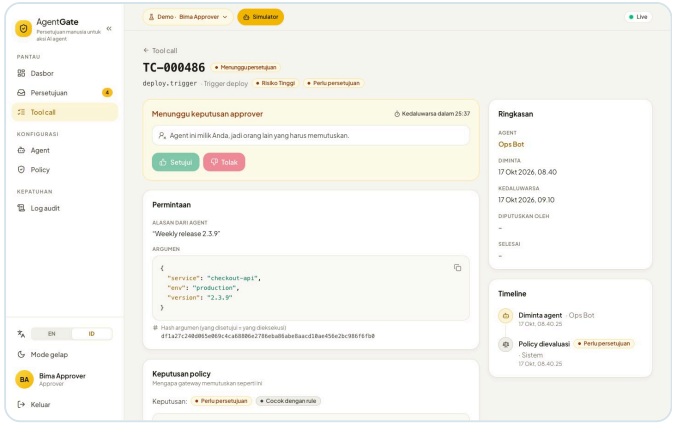
4 Buka inbox persetujuan

Tutup simulator dan buka Persetujuan. Refund yang baru dikirim muncul dengan label "baru saja", hitung mundur kedaluwarsa, ringkasan argumen, dan alasan dari agent.



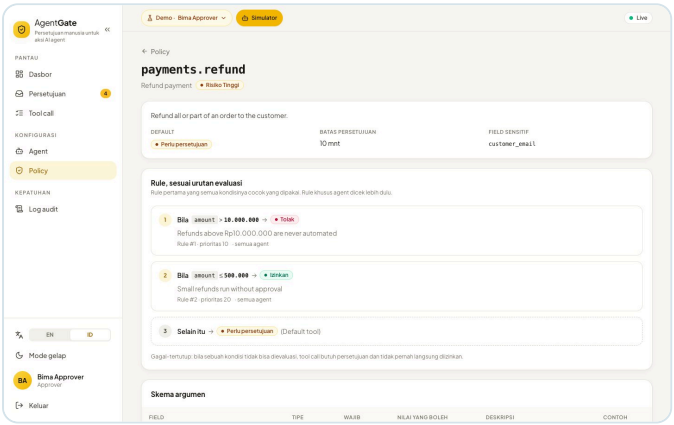
5 Tinjau lalu setujui

Klik Tinjau. Halaman detail menampilkan argumen (customer_email dimasking), hash argumen, dan alasan keputusan policy: tidak ada rule yang cocok untuk Rp2.500.000, jadi berlaku default tool (perlu persetujuan). Klik Setujui, isi catatan, lalu konfirmasi; statusnya menjadi Berhasil dan panel Simulator ikut menerima hasilnya.



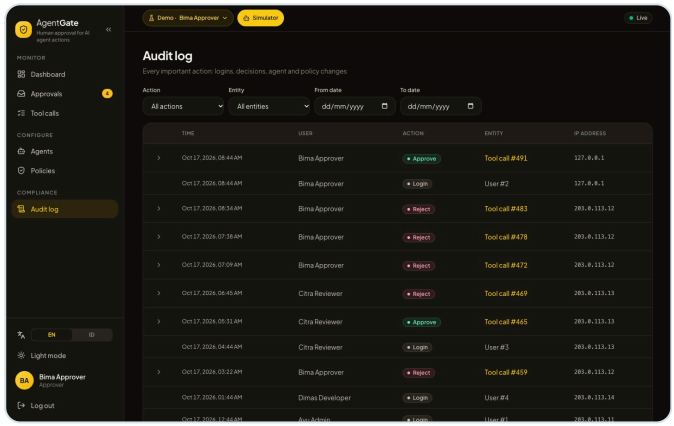
6 Coba menyetujui aksi agent sendiri

Kembali ke Persetujuan dan buka deploy.trigger yang berlabel "Agent Anda". Bima pemilik ops-bot, jadi tombol Setujui dan Tolak terkunci dengan pesan bahwa orang lain yang harus memutuskan. Ganti persona ke Citra Reviewer lewat badge Demo untuk menyetujuinya.



7 Baca policy tool

Buka Policy → payments.refund. Rule ditampilkan dalam bahasa manusia sesuai urutan evaluasi: bila amount > 10.000.000 → Tolak, bila amount ≤ 500.000 → Izinkan, selain itu perlu persetujuan. Di bawahnya ada skema argumen tool.



8 Cek log audit, tema, dan bahasa

Buka Log audit untuk melihat persetujuan yang baru Anda buat, lengkap dengan waktu, pengguna, dan alamat IP. Klik Mode gelap dan EN di sidebar untuk mengganti tema dan bahasa. Menu Reset data demo di badge Demo mengembalikan data ke kondisi awal.

KETERBATASAN & CATATAN

- Demo live berjalan tanpa backend: data tersimpan di localStorage browser masing-masing pengunjung, dan aturan gateway ditiru di TypeScript (diuji dengan test vector yang sama dengan backend Go).
- Keenam tool adalah sandbox: mensimulasikan latensi 300–900 ms tanpa efek samping nyata. Belum ada executor yang memanggil layanan HTTP sungguhan.
- Rule policy masih di-seed lewat SQL; console baru bisa membaca policy, belum mengedit.
- Hub realtime ada di memori, jadi backend harus dijalankan sebagai satu instance. Aplikasi mobile butuh backend yang berjalan dan belum dirilis ke Play Store/App Store.

RENCANA BERIKUTNYA

- Editor policy dengan simulator dry-run sebelum rule disimpan.
- Dua approver untuk tool berisiko Kritis, dan notifikasi push Android (FCM) untuk aplikasi approver.
- Adapter MCP di atas gateway dan executor HTTP sungguhan untuk layanan upstream.